BÁO CÁO CÁC LỖI CẤY THÊM NGOÀI ĐẶC TẢ SRS

MÔN HỌC: ĐẢM BẢO CHẤT LƯỢNG PHẦN MỀM (SQA) - BCSE2023
Hệ thống: Mini HRM Leave Portal (v3.3)
Tài liệu quy chiếu: SRS_Leave_Management_System.md

1. BẢNG TỔNG HỢP 3 LỖI

Mã Bug	Tên lỗi	Phân loại	Mức độ	Vị trí mã nguồn
BUG-01-LOW	Vỡ giao diện bảng lịch sử khi lý do chứa chuỗi dài liên tục không ngắt quãng	UI/UX Display Glitch	Low	frontend/src/pages/EmployeeDashboard.tsx (dòng ~580)
BUG-02-MEDIUM	Tạo đơn nghỉ phép trùng lặp do thiếu Debounce/Disable nút gửi (Double Submission)	Functional / Race Condition	Medium	frontend/src/pages/EmployeeDashboard.tsx (dòng ~490)
BUG-03-HIGH	Lỗ hổng IDOR cho phép nhân viên rút/hủy đơn của người khác	Security / Broken Access Control	High	backend/src/leave/leave.service.ts (dòng ~320)

2. CHI TIẾT TỪNG LỖI & HƯỚNG DẪN KIỂM THỬ

BUG-01-LOW: Vỡ layout bảng khi nhập lý do dài không có khoảng cách

- Vị trí file: frontend/src/pages/EmployeeDashboard.tsx
- Mô tả lỗi:
  - Trong bảng hiển thị lịch sử đơn của nhân viên, ô hiển thị Lý do (req.reason) được đặt thuộc tính whitespace-nowrap overflow-visible và loại bỏ cơ chế cắt chuỗi.
  - Khi nhân viên nộp đơn có lý do là một chuỗi ký tự liền nhau không có dấu cách, ô dữ liệu bị kéo giãn vô hạn theo chiều ngang.
- Hậu quả:
  - Cột lý do làm phình to chiều rộng toàn bộ bảng dữ liệu, đẩy các cột quan trọng phía sau văng ra khỏi khung hình bên phải.
  - Gây thanh cuộn ngang khó chịu và phá vỡ tính tương thích giao diện Responsive (NFR-01).

- Các bước tái hiện (Steps to Reproduce):
  1. Đăng nhập với tài khoản nhân viên: `an.nguyen@company.vn` / `Pass@123`
  2. Tại form xin nghỉ phép, chọn ngày và loại phép bất kỳ.
  3. Tại ô Lý do nghỉ, nhập chuỗi ký tự liền nhau không khoảng trắng dài hơn 80 ký tự.
  4. Bấm 'Nộp đơn xin nghỉ phép'.
  5. Bảng bị vỡ layout ngang, thanh cuộn xuất hiện.
- Kết quả thực tế (Actual Result): Cột bảng bị kéo giãn không giới hạn, mất cân đối UI.
- Kết quả mong đợi (Expected Result): Chuỗi dài phải được tự động ngắt dòng (break-words) hoặc hiển thị dạng rút gọn (truncate).

BUG-02-MEDIUM: Lỗi gửi đơn trùng lặp do thiếu Debounce / Disabled khi Submit

- Vị trí file: frontend/src/pages/EmployeeDashboard.tsx
- Mô tả lỗi:
  - Nút bấm [Nộp đơn xin nghỉ phép] bị loại bỏ thuộc tính disabled={submitting}.
  - Khi mạng chậm, nếu double-click nhanh, 2 yêu cầu HTTP gửi đi song song và lọt qua check BR-13.
- Hậu quả:
  - Tạo ra 2 bản ghi đơn nghỉ phép giống hệt nhau.
  - Gây hoang mang cho quản lý và có thể bị trừ đúp quỹ phép.
- Các bước tái hiện (Steps to Reproduce):
  1. Đăng nhập tài khoản nhân viên: `an.nguyen@company.vn` / `Pass@123`
  2. Điền thông tin hợp lệ.
  3. Chỉnh mạng về Slow 3G trong F12.
  4. Nhấn đúp chuột thật nhanh vào nút 'Nộp đơn'.
  5. Có 2 đơn trùng ngày được tạo ra.
- Kết quả thực tế (Actual Result): Hệ thống tạo ra 2 đơn nghỉ phép trùng thời gian.
- Kết quả mong đợi (Expected Result): Nút gửi phải bị vô hiệu hóa ngay từ cú click đầu tiên.

BUG-03-HIGH: Lỗ hổng IDOR cho phép rút đơn của nhân viên khác

- Vị trí file: backend/src/leave/leave.service.ts
- Mô tả lỗi: API DELETE /api/leave/request/:id/recall không kiểm tra xem đơn có thuộc về người dùng đang đăng nhập hay không.
- Hậu quả: Lỗ hổng Broken Object Level Authorization (IDOR - OWASP API Security Top 1). Bất kỳ ai cũng hủy được đơn của người khác nếu dò được requestId.
- Các bước tái hiện (Steps to Reproduce):
  1. User A đăng nhập: `an.nguyen@company.vn` / `Pass@123` , tạo đơn và copy id.
  2. Đăng xuất.
  3. User B đăng nhập.
  4. Dùng Postman/Console gọi API DELETE recall với id của A.
  5. Trả về HTTP 200 OK.
  6. Đơn của A bị hủy.

- Kết quả thực tế (Actual Result): B hủy được đơn của A mà không bị chặn.
- Kết quả mong đợi (Expected Result): Server trả về 403 Forbidden.